

Block 11p: manual CI evidence prerequisites

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Target: fork audit/715-stack08-10-agent3-integration, PR #876, exact Block 10 head 3a6f1cc2452c268908871958fe75abc5b3a2d54f. Code generation predecessor: 047a52c3dd6cc6ee0eed5e62a7004a350a1f8fef. The final containing head belongs in the PR body. Main-worktree master template SHA256: c754673f39e8a2235254f807fd26827669f53b0d119a5f954ca6c8c898bd44c8.

1. Scope and source reconciliation

This small prerequisite precedes bounded firmware unit 11a because a manual CI run on 11a at cc2de59ff4479667ad4b85d88962a24ce39501cf exposed two Stage 1 failures inherited from the accepted Block 10 base. The manual workflow scans the current tree without Git history, and two historical JSON lines containing public dependency commit IDs lacked no-git ignore fingerprints. The report-authority regression test inherited the runner's workflow_dispatch event even while mocking a pull request event, causing a false test failure. Both fixes already exist in the qualified cumulative Block 11 tree and are extracted unchanged here. No firmware product source, binary, dependency pin or waiver authority is changed. The script keeps the pull request event explicit inside its test; the scanner ignores only the two exact public gitlink lines.

All direct and nested submodules were initialized at the Block 10 pins and checked clean. The direct pins are code-signing-keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec; deps/crypto/trezor-firmware 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; deps/device-protocol 5fec9e6906a340be5eb3d795ec746769065b2db8; deps/googletest 7888184f28509dba839e3683409443e0b5bb8948; deps/python-keepkey 41af909341965c81b8afadd38f299d6f929089af; deps/qrenc/QR-Code-generator 6dfbfadad5d9303ed190d1c3cb7bec34b565b6ce8; deps/sca-hardening/SecAESSTM32 71d356a1141624994cf613bd2d2583892e8e6d5a.

2. Findings, controls and limits

The scanner finding concerns public commit SHA strings in docs/release/audit-units/715-09-reconciliation-20260927.json, lines 134 and 138. Its observer is CI's no-git Gitleaks scan; the allowed outcome is zero findings for those reviewed identities while other file/rule/line identities still scan. The forbidden outcome is a broad docs or dependency exemption. With the old ignore list, a local no-git scan reports exactly two findings; with the two precise entries, it reports zero. No secret value was printed in the evidence. Local Gitleaks is 8.30.0; hosted CI pins and verifies 8.30.1, so hosted qualification is required.

The authority test's sensitive state is the independently accepted capability waiver base. Its observer is scripts/test_generate_test_report.py under the hosted manual event. The allowed behavior is to model a pull request event explicitly and reject missing/invalid pull request base identities; the forbidden behavior is to accept the runner's independent manual authority for that modeled pull request. With GITHUB_EVENT_NAME=workflow_dispatch and the accepted repository authority present, the original targeted test fails because an invalid pull request event is accepted. The fixed targeted test passes, and all 18 report gate tests pass. Candidate waiver scope and generator logic are unchanged.

The deterministic six-member 715-11p-controls-20260928.tgz archive has SHA256 b54513a291de60a95f048ec2305bde2d17ae4c8a648222f277ba907fa472856d. Its manifest binds five raw logs, the base, code commit and positive/negative outcomes. Every member hash verifies; a modified log is rejected. The failed 11a hosted run is preserved as provenance, not counted as 11p qualification. Previous Block 10 native/device acceptance is carried only for unchanged product code.

3. Local and external checkpoint

The two old-source negative controls fail for their expected reasons and the fixed scanner plus 18 report tests pass. Direct/nested dependency status and source diff are clean. Final post-edit preflight, hosted exact-head CI and review delivery are recorded after report freeze in the PR body. This is a code-bearing CI-policy/test unit with a fresh three-round Copilot budget under the owner's recursive split authority. No clean external verdict or release acceptance is claimed here.

4. Complete adjacent Git inventory

Inventory base: 3a6f1cc2452c268908871958fe75abc5b3a2d54f. The code predecessor is 047a52c3dd6cc6ee0eed5e62a7004a350a1f8fef; the report generation predecessor and final containing head are recorded in the PR body. Reproduce from the immutable base to that final head with git diff --numstat 3a6f1cc2452c268908871958fe75abc5b3a2d54f..FINAL_PR_HEAD. The report and PDF rows are included; binary counts use Git's dash.

Added	Deleted	Path
-------	---------	------